THREAT HUNTING FRAMEWORKS · 01

PEAK: Prepare, Execute, Act with Knowledge

A practical hunting framework from Splunk SURGe (David Bianco and team, 2023), built on the older Sqrrl hunting loop. It names three kinds of hunt and gives every hunt the same three phases, so hunts are repeatable, measurable and always end in something the SOC can use.

Hypothesis-driven
Start from a specific, testable idea about adversary behaviour and prove or disprove it.

Baseline (EDA)
Profile what normal looks like in one data source, then investigate what doesn't fit.

Model-assisted (M-ATH)
Let clustering, anomaly or scoring models surface candidates; humans decide.

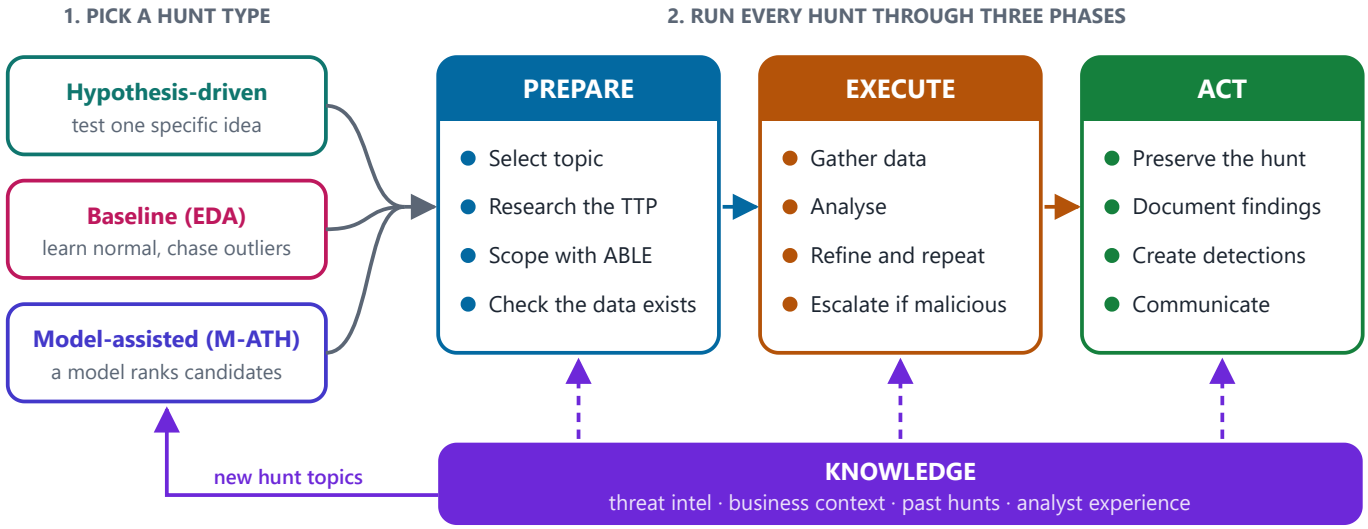


Figure 1. PEAK at a glance. Choose a hunt type, run it through Prepare → Execute → Act. Knowledge feeds every phase, and every hunt adds back to it.

> **The core idea.** The hunt type changes *how you find* candidates. The phases are the same for all three, which is what makes a hunt programme measurable: every hunt is scoped the same way, timeboxed the same way and closed out with the same deliverables.

1. The three hunt types

	Hypothesis-driven	Baseline (EDA)	Model-assisted (M-ATH)
Starts from	A specific TTP you suspect	A data source you don't fully understand	A question too big or too subtle for stacking
Core method	Targeted queries for known indicators of the behaviour	Stacking, frequency counts, distributions, long-tail review	Clustering, isolation forest, beacon or DGA scoring
Typical output	Confirmed or refuted hypothesis, new detection	Documented baseline, list of anomalies, new hypotheses	Ranked candidate list, reusable model or notebook
Main risk	Tunnel vision: only finds what you looked for	Rabbit holes in benign rare activity	Treating a model score as a verdict
Example	"Adversaries use comsvcs.dll MiniDump to dump LSASS on servers."	All parent → child process pairs on domain controllers	Score every internal → external pair for beacon regularity

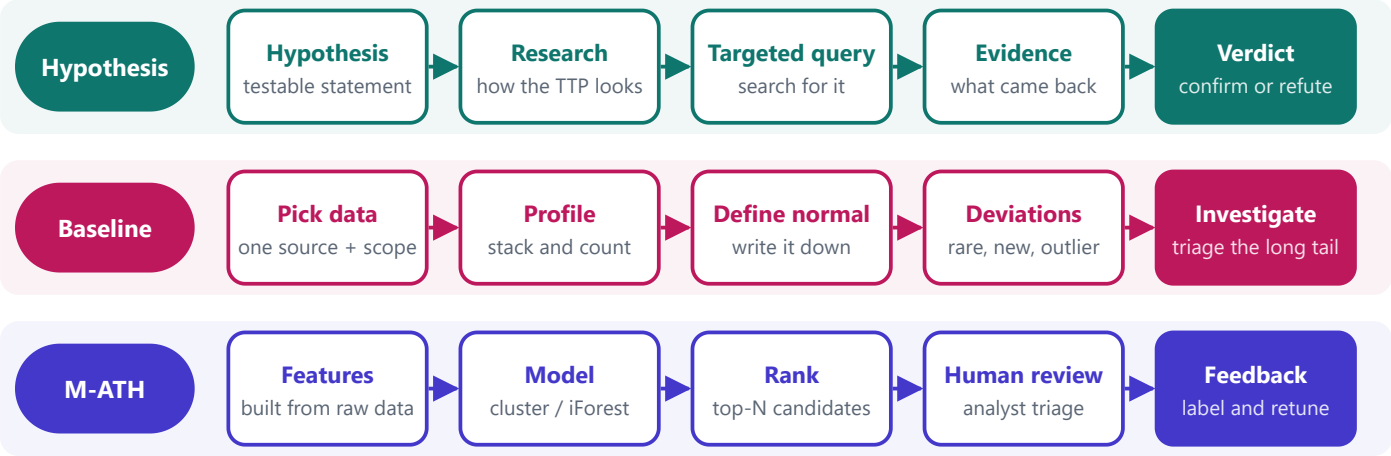


Figure 2. How each hunt type moves from data to a result. The filled box is the output.

1.1 Hypothesis-driven: scope it with ABLE

PEAK scopes a hypothesis with **ABLE**. If you can't fill in Behavior, Location and Evidence, the hypothesis isn't testable yet. Actor is optional: most hunts target a behaviour many actors share.

ABLE	Question	Worked example: LSASS dump with comsvcs.dll
Actor	Who? (optional)	Hands-on-keyboard intruders, for example ransomware affiliates
Behavior	What exactly do they do?	`rundll32.exe comsvcs.dll, MiniDump <lsass PID> out.dmp full` (T1003.001)
Location	Where in our estate?	Windows servers, especially jump hosts and file servers, last 30 days
Evidence	Which data proves or disproves it?	EDR or Sysmon EID 1 (command line), Sysmon EID 10 (lsass access mask), EID 11 (.dmp written)

CORTEX XDR · XQL · process starts

```
dataset = xdr_data
| filter event_type = ENUM.PROCESS and event_sub_type = ENUM.PROCESS_START
| filter action_process_image_name = "rundll32.exe"
    and action_process_image_command_line ~= "(?i)comsvcs(\.dll)?.{0,10}(minidump|#\+?0*24)"
| fields _time, agent_hostname, actor_effective_username,
         actor_process_image_name, action_process_image_command_line
```

SPLUNK · SPL · who opened lsass?

```
index=sysmon EventCode=10 TargetImage="*\\lsass.exe"
| where NOT match(SourceImage, "(?i)\\\\(MsMpEng|csrss|wininit|lsm)\.exe$")
| stats count values(GrantedAccess) as access by host, SourceImage
| sort - count
```

The second query keys on the **behaviour** (a handle to lsass), so it still works when the tool is renamed or the attacker uses ordinal #24.

1.2 Baseline: profile normal, then chase the tail

Pick one data source and one scope. Stack it, write down what normal is, and investigate the rare tail. You are not looking for a known TTP, but the tail often contains one. A baseline hunt also leaves behind a reusable artifact: the documented baseline that later hunts and detections compare against.

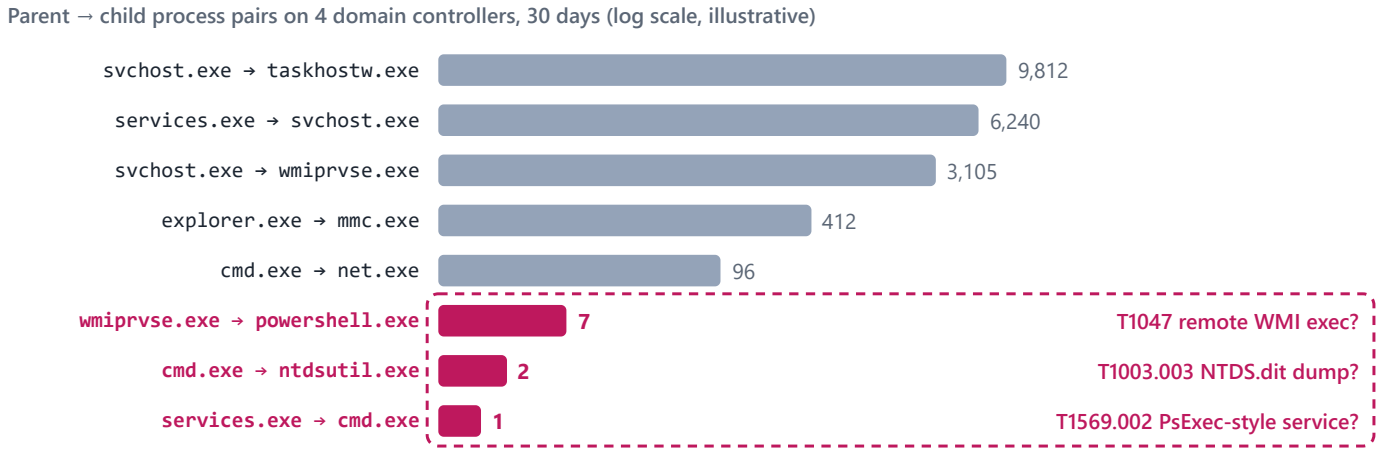


Figure 3. Stacking parent → child pairs on DCs. The three rarest pairs map to real techniques and are worth investigating first.

CORTEX XDR · XQL · stack process pairs on DCs

```
dataset = xdr_data
| filter event_type = ENUM.PROCESS and event_sub_type = ENUM.PROCESS_START
| filter agent_hostname in ("DC01", "DC02", "DC03", "DC04")
| comp count() as runs, count_distinct(agent_hostname) as hosts
      by actor_process_image_name, action_process_image_name
| sort asc runs
```

Senior tip. Count *distinct hosts* as well as events. A pair seen 500 times on one DC is more suspicious than a pair seen 500 times spread evenly across all four. Normalise command lines (strip GUIDs, PIDs and temp paths) before stacking, or every row is unique.

1.3 Model-assisted (M-ATH): models rank, humans decide

Use M-ATH when the signal is spread across several weak features (interval regularity, byte-size consistency, connection count) or the volume is too high to stack. The model's job is to put the 20 most interesting rows in front of an analyst, not to declare anything malicious.

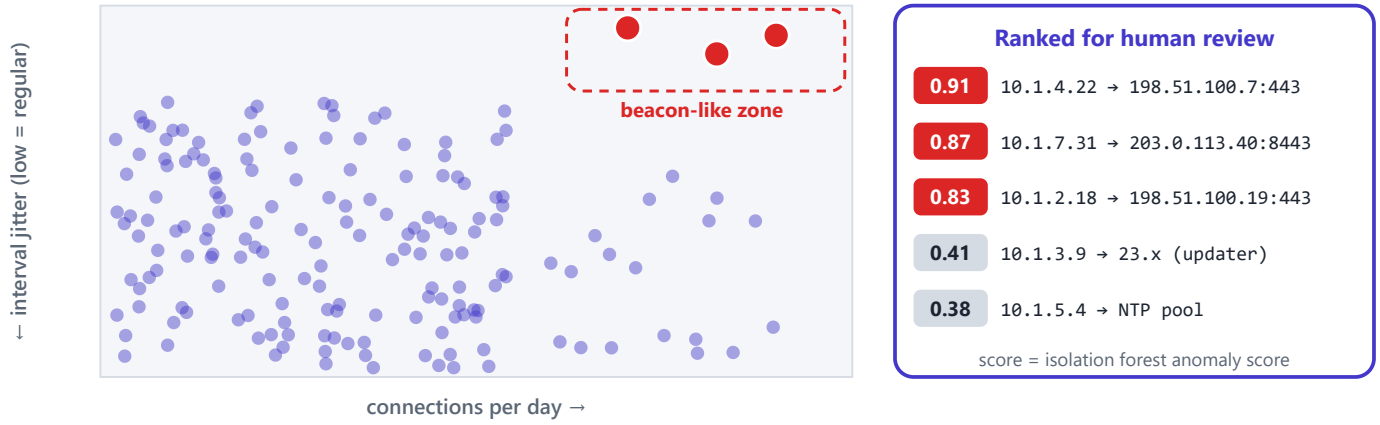


Figure 4. Beacon hunting with an isolation forest: regular, frequent connections stand out from normal traffic (illustrative data).

Make it defensible. Keep the feature list, the model version and the allow-list (updaters, NTP, EDR cloud) in the hunt repo. Label what analysts confirmed or dismissed and feed it back. A model nobody can explain is not usable in an incident report.

2. The three phases

PREPARE

1. **Select a topic:** from intel, recent incidents, ATT&CK coverage gaps or a red team report.
2. **Research:** how the technique really looks in telemetry, and its variants.
3. **Scope:** write the hypothesis with ABLE, set the time range, hosts and a timebox.
4. **Check the data:** confirm the logs exist, are complete and are retained long enough.

EXECUTE

1. **Gather:** run the queries, export the data into a notebook if needed.
2. **Analyse:** stack, pivot on host and user, join process, network and auth data.
3. **Refine:** remove known-good, widen or narrow, repeat.
4. **Escalate:** anything malicious goes to IR at once. Don't keep hunting a live intrusion.

ACT

1. **Preserve:** queries, notebooks and data references go into the hunt repo.
2. **Document:** hypothesis, scope, method, findings, gaps.
3. **Create detections:** turn what worked into a rule with known false positives.
4. **Communicate:** SOC, IR, detection engineering and the data owners.

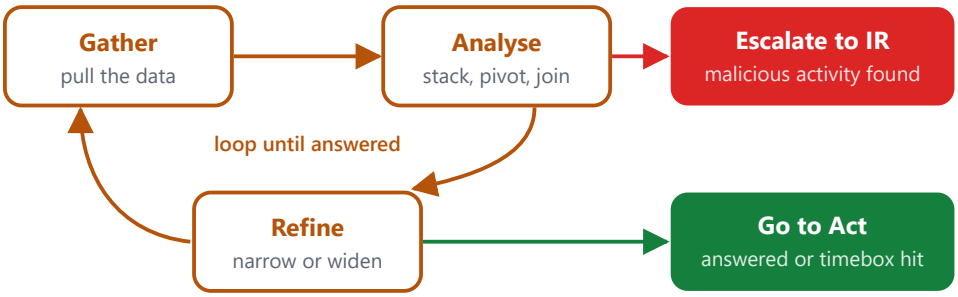


Figure 5. Execute is a loop with two exits: escalate to IR, or move to Act when the question is answered or the timebox runs out.

What Act must produce

Output	Where it goes	Example
Preserved hunt	Hunt repo (version control)	hunts/H-2026-014/: queries, notebook, hunt card
Hunt report	Wiki or ticket	Hypothesis, ABLE scope, method, results, false positives, gaps
New detection	Detection-as-code repo	Sigma rule for rundll32 + comsvcs + MiniDump, with test data
Data gap	Logging backlog	"Sysmon EID 10 missing on 30% of servers": this is a finding too
Knowledge	Hunt backlog and team	New hypotheses that came out of this hunt

> **Knowledge is the K in PEAK.** Threat intel, knowledge of the business (which servers matter, which admin tools are normal), past hunt results and the hunter's own experience feed every phase. A hunt that finds nothing still adds to it: you now know the behaviour is absent *and* that you could see it if it happened.

3. Choosing the hunt type

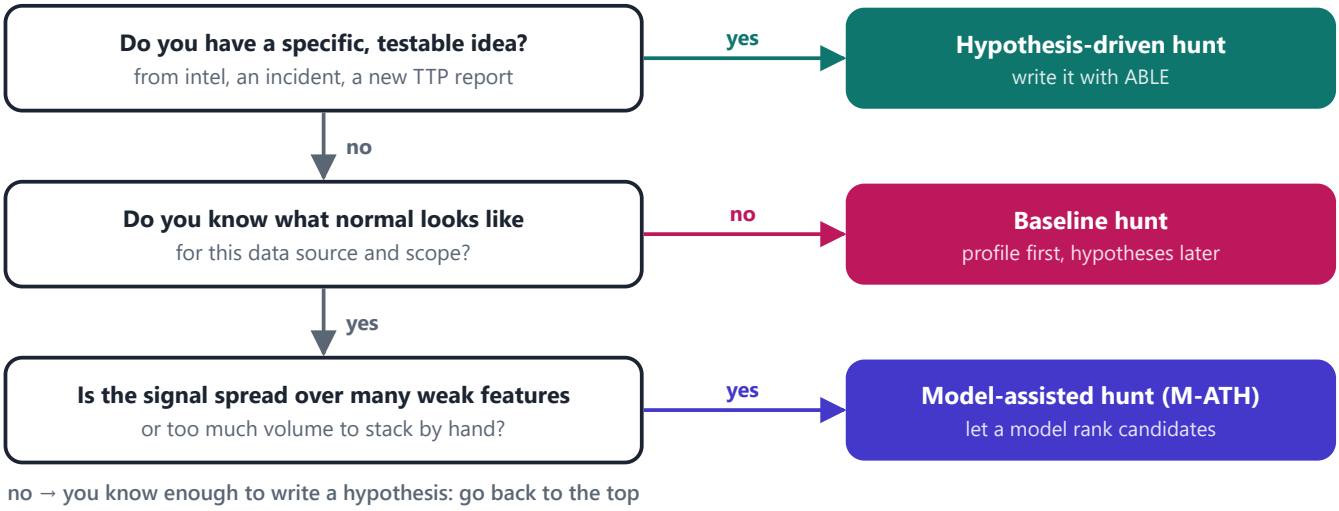


Figure 6. A quick way to choose. Baseline and M-ATH hunts usually end by producing hypotheses for the next hypothesis-driven hunt.

4. Mistakes experienced hunters still make

"No evidence" reported as "clean"
If the data check in Prepare was skipped, a null result may only mean you had no visibility. Report both separately.

Hypothesis too broad
"Attackers are moving laterally" isn't testable. ABLE forces a behaviour, a location and the evidence.

No timebox
Execute can loop forever. Set a limit in Prepare and go to Act when it runs out.

Act stops at the report
The lasting value is the detection, the saved queries and the data gaps fixed.

Model score treated as a verdict
M-ATH ranks candidates. An analyst still confirms every one.

Stale baselines
Normal drifts with patches and new tools. Date every baseline and re-run it.

5. Measuring a PEAK hunt programme

Metric	Why it matters
Detections created from hunts	Shows hunting is improving automated coverage, not just finding one-off issues
Data gaps found and fixed	Every fixed gap makes future hunts and detections possible
ATT&CK techniques hunted	Coverage map; shows where you have never looked
Incidents found by hunting	Important but rare. Don't make it the only metric, or hunters chase easy wins
Hunts preserved and re-runnable	A hunt that can be re-run next quarter is worth far more than a one-off

One-line summary for an interview. "PEAK gives every hunt the same lifecycle: Prepare (topic, research, ABLE scope, data check), Execute (gather, analyse, refine, escalate), Act (preserve, document, detect, communicate). I pick hypothesis-driven when I have a specific TTP, baseline when I need to learn normal first, and M-ATH when the signal is too subtle or too large to stack. Every hunt ends with a detection or a documented gap."

Source: The PEAK Threat Hunting Framework, Splunk SURGe (2023). Counts, IP addresses and scores in the figures are illustrative.